

Section 5 - Business Rules

Business Rules define the core logic of the application. Unlike API validation, these rules ensure that business operations remain consistent, secure, and financially correct regardless of which client (web, mobile, AI, or integrations) invokes the APIs.

1. Authentication Rules

- Only authenticated users can access protected APIs.
- JWT Access Token is required for every secured request.
- Refresh Tokens are stored securely and can be revoked during logout.
- Accounts can be ACTIVE, BLOCKED, or SUSPENDED.
- OTP/password validation must succeed before login.

2. Store Rules

- Each user can own one or more stores.
- GSTIN must be unique for every store.
- Invoice prefix must be unique within a store.
- Store settings are isolated from other businesses (multi-tenancy).

3. Customer Rules

- Customers belong to exactly one store.
- Customers are never permanently deleted.
- Status changes between ACTIVE and INACTIVE.
- Customer statements include invoices, payments, and balances.

4. Product Rules

- Products are store-specific.
- Negative selling price is not allowed.
- Inactive products cannot be sold.
- Deleting products is prohibited; use active=false.

5. Inventory Rules

- Stock cannot become negative.
- Every stock movement creates an inventory history record.
- Sales reduce stock automatically.
- Stock-in and stock-adjustment operations require audit logs.

6. Transaction Rules

- Transactions are immutable after completion.
- Transactions are never deleted.
- Refunds or mistakes use transaction reversal.
- Invoice numbers cannot be duplicated.
- PDF invoice is generated after successful transaction.

7. Expense Rules

- Expenses belong to one store.
- Negative expense amounts are not allowed.
- Approved expenses cannot be modified without authorization.

8. AI Rules

- AI only accesses data belonging to the authenticated store.
- Every AI conversation is stored for history.
- AI responses never bypass authorization rules.

9. Notification Rules

- Notifications are generated for low stock, overdue payments, and important business events.
- Users can mark notifications as read but not modify their contents.

10. Audit Log Rules

- Important actions are recorded with user, timestamp, IP, and action details.
- Audit logs are append-only and cannot be edited.

11. Security Rules

- Every request passes authorization checks.
- Rate limiting protects authentication and AI endpoints.
- Sensitive information is encrypted or hashed.

12. Financial Rules

- Invoice totals = subtotal + taxes - discounts.
- Paid invoices cannot be edited.
- Cancelled invoices remain in history for auditing.

Example Business Flow

Create Transaction

Validate User → Validate Customer → Validate Product Availability → Reduce Inventory →
Generate Invoice → Save Transaction → Create Audit Log → Send Notification → Generate PDF